

Browser-in-the-middle attacks: A comprehensive analysis and countermeasures

Raut Omprakash Jagannath | Ankit Kumar Jain[✉]

National Institute of Technology
Kurukshetra, Kurukshetra, India

Correspondence

Ankit Kumar Jain, National Institute of
Technology Kurukshetra, Kurukshetra,
India.
Email: ankit.jain2407@gmail.com

Abstract

A browser-in-the-middle (BITM) attack occurs when an attacker intercepts and manipulates communication between a user's web browser and the website they are attempting to visit. This approach is risky, as it allows the attacker to eavesdrop on crucial information, such as login passwords or financial details, leading to unauthorized access and potential data breaches. Moreover, the attacker can inject malicious content into the conversation, compromising the integrity of the data shared between the user's browser and the website. The article delves into the BITM attack as a strategy employed in phishing assaults. The article emphasizes precautionary measures to safeguard against BITM attacks. Additionally, it offers insights into how users can defend themselves and respond to an attack. The significance of user awareness in avoiding phishing attempts is a key highlight of the article.

KEYWORDS

browser in the middle attack, phishing, web browser

1 | INTRODUCTION

A modern sort of attack used for phishing is called a "Browser in the middle attack" (BITM). It involves an attacker intercepting and changing the communication between a user's web browser and a website.¹⁻³ The communication route between a user's browser and a targeted website is intercepted and monitored as part of a BITM attack, also known as a Man in the Middle assault unique to browsers^{1,3} as shown in Figure 1. The attacker effectively served as a proxy by placing himself between the user's browser and the target website. Unknowingly sharing information with the attacker, who then forwards it to the desired website, the user communicates with the attacker.⁴

BITM attack tricks its victim into believing they are browsing normally and that the connection is secure.¹ The victim's movements while gazing out the open window are actually captured on the adversary's computer. The attacker has accessed these victim-authenticated sessions. The adversary has the ability to capture all input data, including usernames and passwords, and can alter the content that is shown to the victim or may be this attack will be used as a ransomware attack. Browser in the middle attacks can be used to compromise multifactor authentication systems that rely on user input and avoid the hardware-based secret exchange.^{1,3}

1.1 | History and statistics

The BITM attack can be considered as a modern phishing technique. Researchers from corporations and academic institutions are equally interested in phishing and BITM scams because they pose a severe risk to online privacy and security. Firewalls and other encryption tools are not effective to stop phishing and BITM attack.^{5,6}

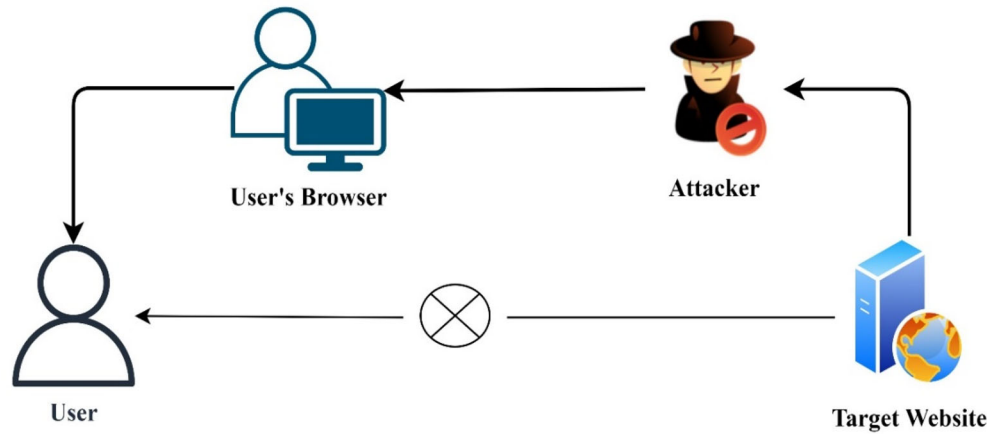


FIGURE 1 Architecture of browser in the middle attack.

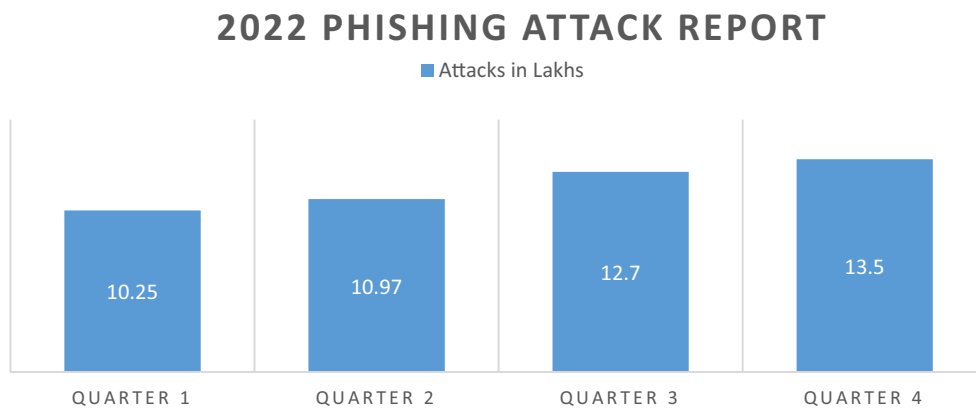


FIGURE 2 APWG report of phishing attack.⁵

Figure 2 presents the total number of phishing attacks reported by APWG in 2022.⁵ According to the MITER ATT&CK paradigm,^{7–10} phishing assaults may be classified into a number of strategies and approaches. Some of the tactics are Initial access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential access, Discovery, and so on. Table 1 provides a detail overview of how phishing attacks fits into various tactics and techniques which are mentioned in MITER ATT&CK framework.

In March 2017, an unusually complex identity phishing campaign emerged targeting approximately 1 billion Google Gmail users worldwide, seeking to take control of their entire email history and spread to everyone in their contact list. The worm entered a user's inbox pretending to be an email from a trusted contact that asked the user to view an attached "Google Docs" or GDocs file.^{11–13}

When they clicked on the link, they were redirected to a real Google security page, where users were asked to allow the fake app, impersonating GDocs, to manage the user's email account.^{11–13} Worse yet, the worm also sends itself to all users. affected a user's Gmail contact list or recurred hundreds of times each time a user fell in love.

The paper is structured as follow: Section 2 presents the working of a BITM attack, including how the attacker gains access to the user's browser and all related procedures. Section 3 presents the differences between BITM, Man in the Middle (MITM) attacks, and Man in the Browser (MITB) attack. In Section 4, various techniques which are used for carried out for BITM attacks are examined. Section 5 presents the prevention techniques and Section 6 discusses various detection techniques employed for preventing and identifying BITM attacks. Section 7 covers fundamental and crucial user awareness methods. Finally, Section 8 concludes the manuscript.

TABLE 1 Tactics and techniques of phishing in MITER ATT&CK framework.

Tactics	Techniques
Initial access	Spearphishing attachment, Spearphishing link, Spearphishing via Service.
Execution	User Execution includes malicious Link, malicious file and malicious image.
Persistence	Browser Extension and Scheduled Task/Job.
Privilege escalation	Hijack Execution Flow and Process injection.
Defense evasion	Masquerading, Obfuscated files or information which includes Steganography, HTML smuggling, Command Obfuscated.
Credential access	Credential Phishing, Network Sniffing and Adversary-in-the-middle which includes ARP Cache Poisoning and DHCP Spoofing.
Discovery	Account Discovery which includes local account, domain account, email account and cloud account.
Lateral movement	Internal Spearphishing and remote services.
Collection	Browser Session Hijacking and Input capture.
Exfiltration	Exfiltration over command-and-control channel.

2 | WORKING OF BITM ATTACK

The working of attack is divided into seven phases which are followed by the attacker to perform the attack. An outline of a BITM attack's potential execution in the actual world is provided in Figure 3.

2.1 | Initial stage

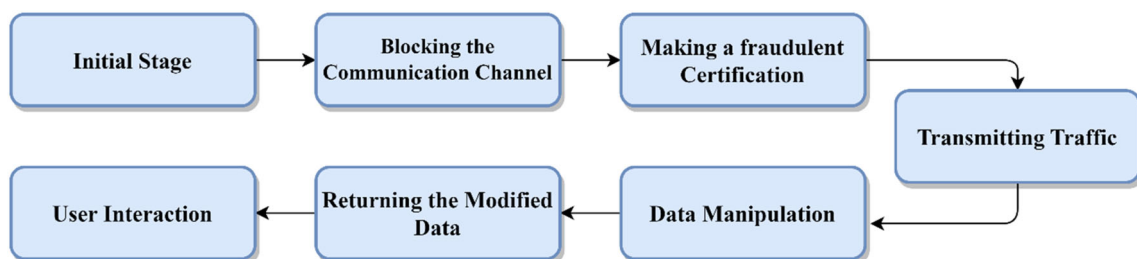
The attacker sends the malicious link using e-mail to the users and after the user opens the link the attacker configures their system (by the help of malicious link) to eavesdrop on network traffic that passes between users and the target website. This can be accomplished in a number of ways and other ways includes compromising the user's network connection, a router, or by setting up a rogue access point.

2.2 | Blocking the communication channel

A user's browser sends a request to the website's server whenever they attempt to connect to that website. The attacker intercepts this request, typically using techniques like DNS or address resolution protocol (ARP) spoofing. As a result, the attacker has the opportunity to block access to the website and the user.

2.3 | Making a fraudulent certification

For the target website, the attacker makes a false SSL/TLS certificate. A certificate authority (CA) that the user's browser trusts has signed the certificate. This step is essential for creating a secure HTTPS connection without causing the user's browser to issue any alerts.

**FIGURE 3** Flowchart of browser in the middle attack.

2.4 | Transmitting traffic

The attacker decrypts the traffic while forwarding the user's request to the trustworthy website using the phony certificate. By doing so, they are able to examine and alter the data that is being sent between the user and the website.

2.5 | Data manipulation

The intercepted traffic is now entirely visible to and under the attacker's control. They have the power to alter the website's content, add malicious code or scripts, steal private information, redirect users to another website, or do any of these things.

2.6 | Returning the modified data

The attacker re-encrypts the modified traffic using the real SSL/TLS certificate of the real website. This step ensures that the updated data is regarded as reliable by the user's browser.

2.7 | User interaction

The attacker modifies the response and sends it to the user's browser, which displays it as if it were the genuine response from the website. The user's accidental interaction with the updated content could weaken the system even more or open the door to unauthorized actions.

A successful BITM attack requires the ability to change SSL/TLS certificates, access to the network infrastructure, and technical understanding. To safeguard oneself from such attacks, users should make sure their devices and browsers are up to date, rely on secure network connections (such as HTTPS), and exercise caution when accessing the internet, especially when entering personal information.

3 | DIFFERENCE BETWEEN SIMILAR TYPES OF ATTACKS

This section discusses the difference between MITM, MITB, and BITM Attack. The differences between these significant attacks are covered in this part because, despite their language appearing to be identical, their operation and mode of attack differ greatly from one another. Table 2 presents a comparison among MITM, MITB, and BITM attacks.

3.1 | Man in the middle attack

A MITM occurs when the attacker places themselves between two parties who are communicating and obtains unauthorized access to the information being transmitted from the communication channel as shown in Figure 4 and x in the figure describes that this path of communication was not followed.⁴ This assault primarily consists of four steps. (i) Intercepting the Communication Channel (ii) Eavesdropping on a channel, (iii) information modification'; (iv) impersonation or predicting as a valid user.^{1,4}

3.1.1 | Step 1: Intercepting the communication channel

In this step, the attacker secretly inserts himself into the communication channel between the sender and the receiver. This can be done by exploiting some vulnerabilities of the network and network protocols or may be compromised network or devices is used by sender or receiver.^{2,14,15}

T A B L E 2 Comparison between browser in the middle, man in the middle and man in the browser attack.

Sr. no.	Criteria	Browser in the middle attack (BITM)	Man in the Browser attack (MITB)	Man in the Middle attack (MITM)
i	Method of attack	With the attacker positioned in-between the user's browser and the server, passive listening and data interception are possible.	A sort of MITM attack in which the attacker uses malware or malicious extensions to penetrate the user's browser or device to monitor and modify data.	Active data interception and modification between two parties (user and server) by presenting the attacker as an intermediate.
ii	Positioning of attacker in attack	Placed between the user's browser and the server.	Placed between a client-side application that exits in the user's browser or device and manipulates data.	Placed between the client and the server, relaying and possibly modifying communications.
iii	Objective of the attack	Without the user's awareness, intercept sensitive data (such as login passwords, credit card or Bank details).	Take over the user's browser experience, keep an eye on their input, and interfere with their online transactions.	Intercept data in route and even change it, allowing for eavesdropping or the introduction of malicious material.
iv	Intensity of attack	This attack is usually undetectable by user as well as server until any detecting tools are placed.	This attack can be partially visible to the user, particularly if the browser or webpage exhibit odd behavior.	This attack is invisibility to the user and server is, but with the right security measures, it may be noticed.
v	Methods of attack	Sniffing or passive eavesdropping on unencrypted traffic, typically in open Wi-Fi networks.	Malicious software or browser add-ons that can alter online content, collect keystrokes, or inject scripts.	Data packet interception and modification, sometimes utilizing ARP spoofing or DNS poisoning.
vi	Examples of software and tools	Tcpdump and Wireshark	SpyEye, Zeus, and banking Trojans	Etercap, Wireshark with ARP spoofing

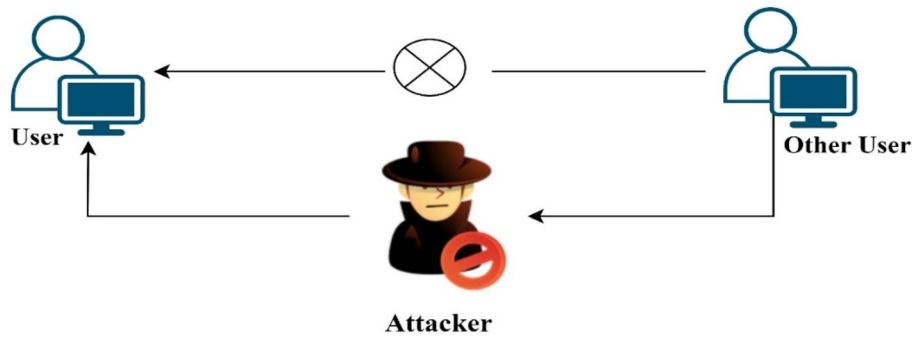


FIGURE 4 Architecture of man in the middle attack.

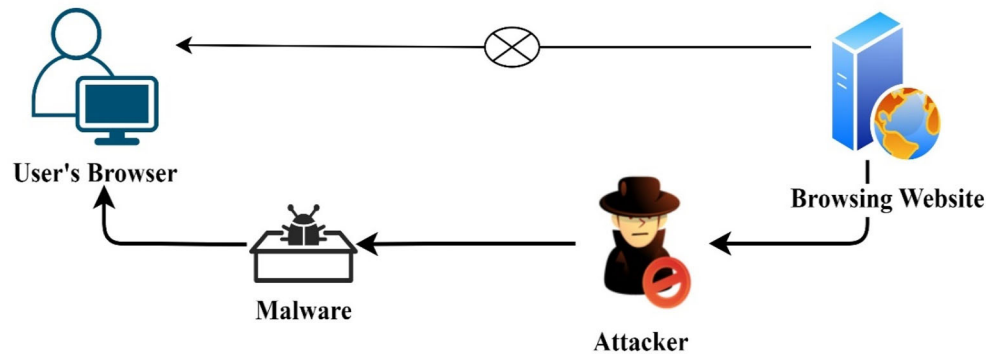


FIGURE 5 Architecture of man in the browser attack.

3.1.2 | Step 2: Eavesdropping on a channel

The attacker can listen in on what user and receiver are saying after they have established themselves as the intermediary. Attacker can view private information, read communications, and record any unencrypted data that is transmitted between the them.^{2,14}

3.1.3 | Step 3: Information modification

Once the Attacker know the information, he/she can easily modify the information and carry forward the fabricated information to the receiver. The attacker can inject the malicious code or program which can be very harmful for the sender's as well as receiver's system.

3.1.4 | Step 4: Impersonation or predicting as a valid user

The attacker uses to act as a legitimate user may be sender, may be receiver and manipulate the information transmitting through the communication channel.

3.2 | Man in the browser attack

Figure 5 presents the architecture of MITB attacks. In this attack, the attacker infects the user's system with malware like trojan horse, remote trojan, and so on, through various ways like phishing emails, malicious downloads or may be by compromised webpages and x in the figure describes that this path of communication was not followed. This attack is carried out in three stages: (i) Infection using malware; (ii) manipulation of user browser; and (iii) information capture.^{16,17}

3.2.1 | Infection using malware

The attacker uses a variety of methods, including phishing emails, attachments, pop-up ads on websites, and infected websites, to send malware to the user's machine. Once the virus has been downloaded into the user's computer, it will begin to run in the background and infect the user's web browser.^{3,18}

3.2.2 | Manipulation of user browser

The malware gains the ability to change how content is presented in the browser. It has the ability to alter web pages, add new scripts, or create pop-up ads which will further be used for the attack. With this skill, an attacker can trick people into giving up sensitive data such as login passwords and financial information and sometimes personal information like photos, videos, and so on.^{2,18}

3.2.3 | Information capture

This malware can capture and send the user's input including credentials information, sensitive information about users. This information can be further used for many purposes like identity theft, fraud, and many more purposes.^{17–19}

3.3 | Browser in the middle attack

The main entities in BITM attack are attacker, victim and its browser, and the targeted website.

3.3.1 | Attacker

Attacker is the computer criminal and its aim is to violating the CIA triad (Confidentiality, Integrity, Availability) of the user. In this attack, attacker use to setup and control the user's browser and use any malicious server which will act as a transparent browser to the user.

3.3.2 | Victim and its browser

The end result of this attack is phishing only. The information of user's browser and all the personal information of the user is compromised with the attacker.

3.3.3 | The targeted website

A web application is targeted which will help attacker to provide information of the user. The attacker used to modify the content of the targeted website to theft the information of the user.^{3,18}

Figure 6 demonstrates how the BITM attack is carried forward. So, first the malicious link is sent to user via email and whenever the user opens his/her browser for browsing the malicious browser is inserted between the user's browser and the browsing website. This is the reason that this attack is also known as MITM specialized for browser. Further, it will convert the user's platform into BITM platform which will help attacker to convert as well as to access any information given by user on that browsing website.

Further, BITM is further divided into two categories: (i) Passive BITM and (ii) Active BITM.

3.3.4 | Passive BITM

This category includes all data collection-only techniques (it goes without saying that the collected data may be freely exploited in the future).^{1,3} The victim's every motion can actually be seen by the assailant in real time. When recording

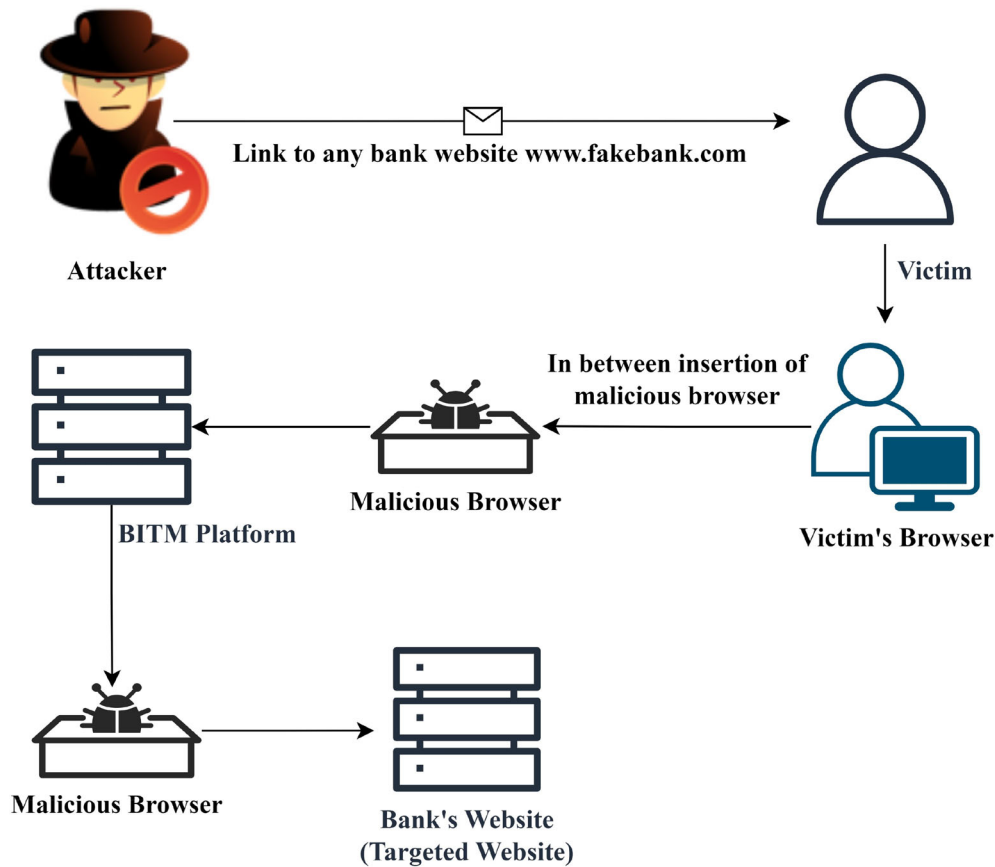


FIGURE 6 Detailed diagram of browser-in-the-middle attack.

the full experience, navigate utilizing the target web application. Installing a keylogger in the malicious web browser is an easy way to record keystrokes (including usernames, IDs, and passwords).¹ By utilizing a web proxy or the proper add-ons, malicious. The entire traffic, including session cookies, can be captured by a web browser.³

3.3.5 | Active BITM

Active BITM encompasses all methods used to actively manipulate the traffic exchanged between the victim and the target web application.³ The malicious server serving the requested page has the power to alter what the victim is intended to see at the original destination in a variety of ways. Furthermore, utilizing the web proxy and add-ons, any type of web-based malware that exploits known browser vulnerabilities may be injected into the victim's browser.³

Because this attack's approach offers the attacker total control over the malicious server as well as the HTML and JavaScript pages delivered to the victim, the range of potential vulnerabilities is, in conclusion only constrained by the attacker's inventiveness once the victim has become entangled. No longer will criminals need to mimic the targeted online applications. To directly exploit the services of the targets, they only need to install software and functionality on the malicious server.

4 | TECHNIQUES USED TO PERFORM BROWSER IN THE MIDDLE ATTACK

This section discusses various techniques used by attackers to carried forward the browser in the middle attack.

4.1 | Exploiting browser plugins or extensions

Attackers may create dangerous plugins or extensions that users install without their knowledge. By inserting code into online pages, altering network requests, or altering browser behavior, an attacker can use these extensions to intercept or tamper with interactions between the browser and websites.¹

In some cases, popular browser extensions that are considered safe are sold or hijacked by shady organizations. Malicious groups that employ such extensions set up updates that can turn seemingly harmless extensions into malware. Compromised extensions connect browsers to command-and-control architectures to filter out sensitive data of unsuspecting users, exposing them to further risks and this risk leads to BITM attack.

4.2 | Wi-Fi packet sniffing

An attacker within range of the target device can capture and examine network traffic if it is linked to an unprotected Wi-Fi network. The attacker can access confidential information such as session cookies or login information by sniffing the packets.¹⁵ Wi-Fi sniffers are packet sniffers or network analyzers that collect packet data on wireless networks. Wireless sniffer solutions are intended to capture and analyze wireless network data in order to obtain insight into what is going on in user's network at all times. Wi-Fi sniffers are sometimes referred to as Wi-Fi packet sniffers and Wi-Fi network sniffers. Wireshark, Nmap, SolarWinds npm, and other sniffing tools are commonly used for sniffing Wi-Fi packets.²⁰ Packet analysis using Wireshark is shown in Figure 7. Attackers can intercept and examine browser traffic using Wi-Fi packet sniffing, which makes it easier to carry out BITM attacks by obtaining session tokens, private information, and the ability to manipulate content. Network procedures and secure protocols like HTTPS are crucial for prevention.

4.3 | MITM proxies

A software program known as a proxy server serves as a middle man between a server and end users, including computers and mobile devices. When a user requests a web page or data, it sends the request to the base server, which hosts resources including files, web pages, and videos. The destination address of the answer is provided by the server. This common practice of requesting web pages or receiving responses from the web server is unsafe because a third party may intercept user's IP address and attack their client device, PC, or terminal.⁴

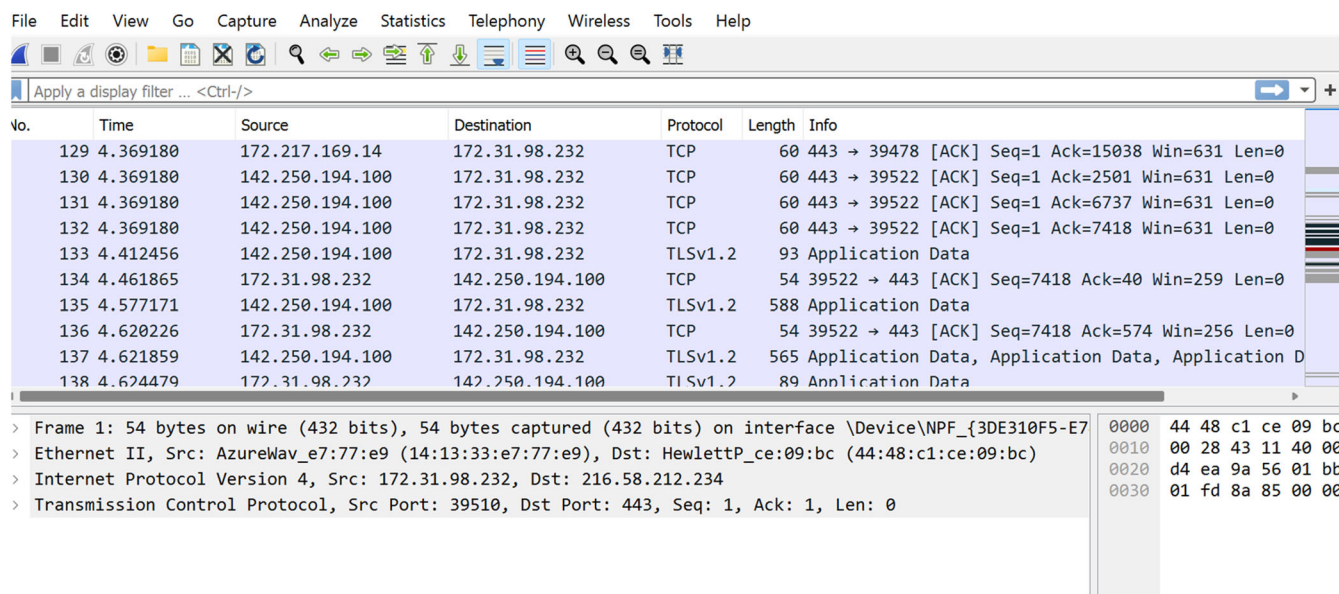


FIGURE 7 Packet analysis using Wireshark.

An attacker can set up a proxy server to act as a go-between for the user's browser and the website. The user's browser is configured to use the proxy, and all traffic is routed through it. As a result, the attacker has the ability to intercept, modify, or record any traffic passing via the proxy.^{2,4} MITM proxies allow for real-time data theft, content alteration, and eavesdropping by putting themselves in the way of user-to-web traffic and intercepting it. For efficient BITM assaults, they are able to take advantage of weaknesses, get private data, and get through encryption.

4.4 | Interception of SSL/TLS

If a website uses SSL/TLS encryption (HTTPS), an attacker could attempt to intercept the encrypted traffic by obtaining and using a counterfeit SSL/TLS certificate or by exploiting holes in the SSL/TLS implementation. As a result, before the communication is delivered to the website, it can be decrypted, checked for accuracy or modification, and then encrypted once more.² The SSL/TLS certificate is shown in Figure 8 how does this certificate looks like.

The distinctions between SSL and TLS are as follows: secure sockets layer (SSL) is a communication protocol or collection of rules that allows two devices or applications to communicate securely over a network. It is critical to build confidence and authenticate the other party before sharing credentials or data over the Internet. SSL is a network security protocol that apps and browsers utilize to establish a secure, encrypted communication channel. SSL, on the other hand, is an older technology with certain security issues. transport layer security (TLS) is an improved version of SSL that addresses current SSL flaws. TLS authentication is faster, and encrypted communication routes continue to be offered.²¹

When SSL/TLS is intercepted during a Bitwise Interception modification BITM attack, encrypted communication can be decrypted, revealing private information that is shared between the web server and browser. This can lead to unwanted access and even data modification. Vulnerabilities can be used by attackers to breach secure connections. When a MITM assault is carried out on SSL/TLS, the assailant intervention the scrambled communication between a client and a server, unscrambles it, and after that re-encrypts it before sending it to the planning beneficiary. This permits

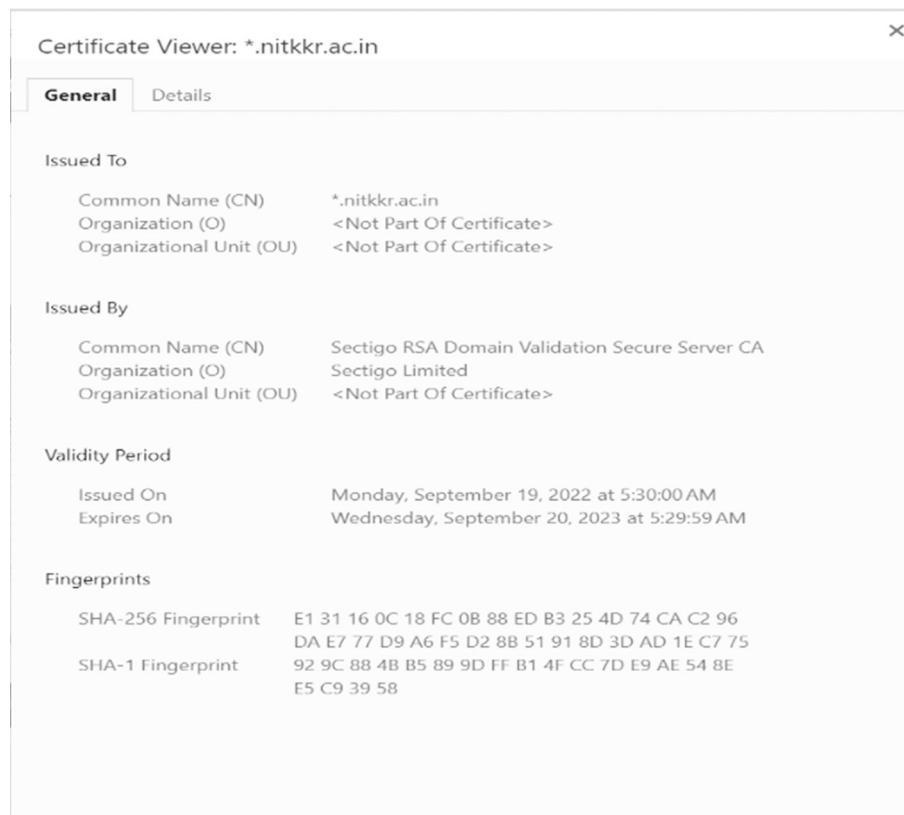


FIGURE 8 SSL/TLS certificate of www.nitkkr.ac.in.

the attacker to get to delicate information, such as login credentials or monetary data, without the parties included being mindful of the interruption.

4.5 | DNS spoofing

By winning the trust of the victim (the target user), hackers can distribute malware and steal information like passwords and PINs that are saved on the victim's device. This type of attack is known as spoofing. The basic goal of spoofing is to psychologically manipulate the victim. A sort of cyberattack known as DNS spoofing involves a hacker intercepting DNS request and responding with bogus data as shown in the Figure 9. If a user attempt to visit [google.com](https://www.google.com), for instance, a hacker may intercept user's DNS request and reply with a phony IP address that points to a malicious website. Linking a legitimate website's domain name to a different IP address under the attacker's control requires altering a target device's or network's DNS cache. When a user attempts to access a website, their browser is instead directed to the attacker's server, enabling communication interception and manipulation.¹⁵

DNS spoofing is typically used to route consumers to a phony website that mimics the legitimate one. A phishing attempt like this one can be used to acquire sensitive data including login credentials, credit card details, and more. In some situations, DNS spoofing can also be used to send people to malicious websites that can infect their computers and steal information or cause other problems. In Figure 8, the client/user initially requests the DNS server, but the attacker intercepts the connection and injects fake DNS entries into the DNS server. As a result, the connection is resolved to a fake website, which is then used for the BITM attack.

With the use of bogus DNS replies, DNS spoofing in a BITM attack enables content modification, phishing, and the capture of sensitive data, all of which can lead an attacker's browser to a hostile website. Inadvertent access and possible security breaches result from this undermining the integrity of the domain resolution procedure.

4.6 | ARP spoofing

ARP is the address resolution protocol. A device's media access control (MAC) address is determined by its internet protocol (IP) address in order for it to connect to other devices on the network. ARP spoofing is a cyber-attack that allows hackers to intercept network device traffic on user's network. ARP spoofing may also be used by hackers to modify or stop all network communication between devices. ARP spoofing is the technique of delivering bogus Address Resolution

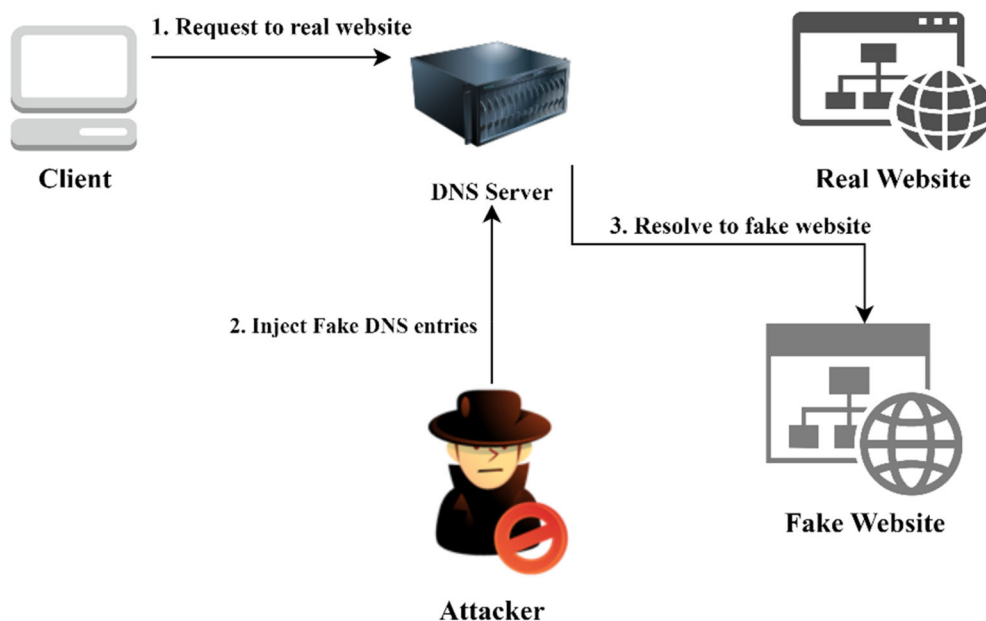


FIGURE 9 Working of DNS spoofing.

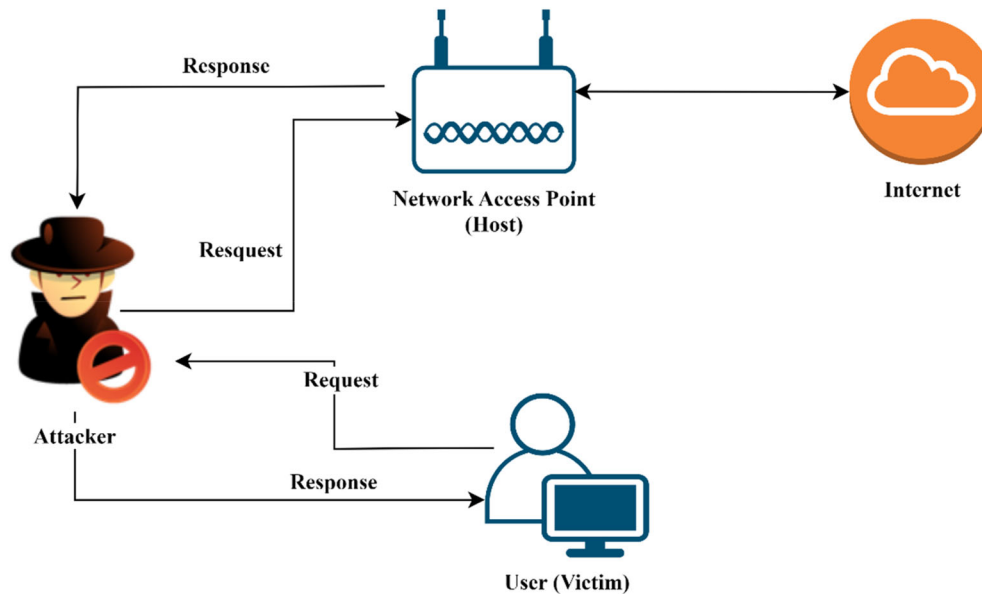


FIGURE 10 Address resolution protocol spoofing example.

Protocol signals to a target device over a local network in order to deceive it into associating the attacker's MAC address with the IP address of a trustworthy website. As a result, the attacker is able to watch how the browser and the website communicate.^{15,22}

The mechanics of ARP spoofing can be categorized into three steps: scanning, selection, and accessing the victim's data. (1) Network Scan: In this step, the attacker/hacker uses her ARP spoofing tool to scan her IP and MAC addresses for hosts. (2) Select and launch an attack. In this step, the attacker/hacker chooses a victim or names a target. The attacker then sent her ARP packets over the network. These packets contain her MAC address of the attacker and her IP address of the target. (3) Access to Victim Information: Attacker's ARP cache for hosts on the local network is corrupted. In this case, any data the host wants to send to the victim will be directed to the hacker, rather than the victim. From here, hackers can steal data or launch other attacks. As shown in the Figure 10, the attacker used to place himself in the middle of the communication and communicate with the victim as a host and change or block the traffic between the devices of the network and the attacker can ask for the ransom to re-established the connection between the devices of the network.

In a BITM attack, ARP spoofing allows attackers to transmit bogus ARP packets to browsers, rerouting network traffic through their system. This makes real-time content alteration, session hijacking, and eavesdropping possible. ARP spoofing is commonly utilized for MITM attacks as well, where the assailant places themselves between a client and a server, allowing them to induce to all the action between the two systems. This may be utilized for distinctive malignant purposes, such as sniffing passwords, reconnaissance, and changing communication.

5 | TAXONOMY OF BITM PREVENTION TECHNIQUES

Phishing scams have been used all over the internet to trick unsuspecting victims into revealing personal information like bank account details, social security numbers, and so on. Additionally, cybercriminals have improved their disguising skills. Sometimes the voices of user's coworkers, bank, or even user's government serve as a cover for these scams. Therefore, this section presents detailed description about some of the prevention techniques which will help us to prevent the phishing attacks as well as browser in the middle attack.

5.1 | Use of an encrypted communication channel

If feasible, users should guarantee that the communication channel is encrypted. Always search for the "https://" protocol in the URL, which shows that the website is using a secure connection, as well as the certificates.^{2,15} Communication

channels lack inherent security by default. Channels can be set to utilize the SSL protocol to ensure their security. SSL is a cryptographic protocol that ensures the security and integrity of data transmitted across TCP/IP networks.

To establish a connection, SSL clients and SSL servers employ a handshake procedure. During this handshake, the client and server agree on the following criteria for connection security: (a) A client requests a secure connection from a server that supports SSL. (b) The server's identification is returned in the form of a digital certificate. A certificate normally comprises the server's identity, the name of a trustworthy CA, and the public encryption key of the server.

Scenario: Transmitting sensitive information, such as financial transactions, personal data, or login information. *Challenge:* Ensure that data remains confidential during transmission and is not susceptible to interception or eavesdropping.

5.2 | SSL/TLS certifications

This certificate helps Internet users to verify the authenticity of the website.¹⁵ Checking the valid certificate of any website will help us to prevent from the phishing websites.²¹

Scenario: Enable HTTPS for websites to secure the transmission of sensitive information, such as login information, personal information, and payment information. *Challenge:* Implement and maintain SSL/TLS certificates to ensure the security and integrity of data transmitted between users and websites.

5.3 | Avoid accessing Wi-Fi

Avoid accessing sensitive data or information like banking information, and so on Wi-fi network as they are unsafe and vulnerable to browser in the middle attacks. If user want to access the information, always use virtual private network (VPN) which will encrypt the connection and protect user's information.³ Using a VPN can be a safe way to browse the Internet. Secure VPNs can protect against IP and Internet history encryption and are increasingly used to prevent spying by government agencies. However, a VPN will not be able to keep you safe in all situations. Using a VPN can be considered secure sufficient for most clients, but it depends on the particular VPN benefit and the user's security prerequisites. A VPN can give encryption, protection, and namelessness for web activity, securing it from interferences and checking by third parties. In any case, not all VPN administrations are similarly secure, and a few may have vulnerabilities or be compromised by malicious actors.

Scenario: Choose not to connect to unsecured Wi-Fi networks to avoid possible data interception and privacy issues. *Challenge:* Investigate secure and private means of communication and Internet access, such as using cellular data or VPNs.

5.4 | Use of two-factor authentication

Two-factor authentication adds an extra layer of protection. Even if the password is hacked, this will prevent unwanted access.¹⁵ MFA provides additional security levels than two-factor authentication (2FA). Customers and employees might be required to utilize passwords, Time-based one-time passwords (TOTP), and Google Authenticator to authenticate their identity. They may make certain that the final user is verified in this manner.²³

Numerous security mechanisms ensure that consumers requesting access are who they claim to be. Even if hackers are successful in stealing one credential, they will need to utilize another means to validate identities. Companies that store sensitive client information should use authentication techniques that require more than two factors. They will be able to win and maintain their clients' confidence.²⁴

Scenario: Deploy 2FA for remote access to corporate networks or sensitive systems. *Challenge:* Ensure employees have access to essential second factors when working remotely and align security policies to support remote access.

5.5 | Avoiding installing malicious browser extensions

Always check whatever user install whether it is browser extension or may be browser plugins. Malicious program or malicious code extensions may be introducing new vulnerabilities to the User's Browser.^{3,15,16}

According to CISA, upgrading your devices, programs, and web browser is a good first step in securing your data and privacy. We frequently advise trying out a security-focused browser like Brave or upgrading the security settings on your current browser to tighten your control over how much of your data is gathered. By utilizing a browser add-on that focuses on security, internet users can increase their level of online protection.^{23,25}

5.6 | Examine the following locations for common Trojans

Many BITM Trojans might be found on your machine in the same spot.²⁶ Examine the following folders for unfamiliar applications: If user find something strange, look it up on the Internet and run it through your antivirus software. Check the following locations: (a) C:/Program Files. (b) C:/Program Files (x86). (c) Windows/Temp.

Because Trojans are used to propagate several forms of malware, if internet user believe their device has been infected by a Trojan, user should check for numerous similar telltale indicators of malware. They might include:

1. Poor device performance—Is your computer or mobile device running slow or crashing more often than usual?
2. Strange device behavior—Are there any running programs that user have not launched or other unknown processes running on your device?
3. Pop-ups and spam interruptions—Have you noticed an increase in interruptions due to browser pop-ups or email spam.

If your equipment exhibits these symptoms, the Trojan horse malware may have infiltrated your computer. Try exploring your computer for apps or applications user do not recall installing. Enter any unknown program or file names via the search engine to see whether they are Trojans.^{26,27}

5.7 | Stay up to date on phishing techniques

New phishing scams are constantly being developed. If users are unaware of these new phishing techniques, users may accidentally fall victim. Be aware of news about new phishing scams. The sooner you can spot them, the less likely you are to fall into a trap.^{28–34} IT administrators are strongly encouraged to conduct ongoing security awareness training and phishing simulations for all users to ensure security is a top priority across the organization.^{32–34}

5.8 | Use of encrypted DNS

Encrypted DNS, such as DNS over HTTPS (DoH) or DNS over TLS (DoT), makes it more difficult for attackers to perform DNS-based attacks in a scenario BITM version. Traditional BITM attacks often involve manipulating DNS responses to redirect users to malicious websites. Encrypted DNS helps protect against such attacks by encrypting DNS traffic, making it more difficult for attackers to intercept or manipulate DNS queries and responses.

Organizations should implement an encrypted DNS protocol to protect against DNS manipulation in transit. Use DNS-based security solutions to detect anomalies and malicious activity.

5.9 | Use of HTTP/3

HTTP/3, the latest version of the Hypertext Transfer Protocol, is designed to improve performance and security. It uses QUIC (Quick UDP Internet Connection) as the underlying transport protocol, thus reducing latency and improving encryption. It may be more difficult for attackers to intercept and manipulate HTTP/3 traffic compared to previous versions.

Organizations as well as users should encourage the use of HTTP/3 to benefit from enhanced security features. Implement strong encryption measures for data in transit to prevent interception and tampering.

Table 3 describes the advantages and disadvantages of the techniques which can be used for precaution and by the table we have a brief information of the techniques.

TABLE 3 Advantages and disadvantages of techniques used for prevention.

Sr. no.	Techniques	Advantages	Disadvantage
i	Use of encrypted communication channel	This technique will help in mitigate cyber-attacks like BITM and also provide data security and data protection.	It is more resource intensive in nature which is a big problem and it is complex in nature.
ii	SSL/TLS certifications	It provides data integrity and be used in authentication of any website.	They don't assure that the browser you are using is secure and BITM attack uses user's browser for attack.
iii	Usage of public Wi-fi	Usage of public Wi-Fi is beneficial as it is cost saving and User can use virtual private network for secure browser.	Fake Wi-Fi network are created for the cyber-attacks and this can be used for BITM attack as well.
iv	Use of two-factor authentication	This technique is used for enhancing the security and this helps for protection of credentials.	In some cases, the authentication is depended on other device and attacker can manipulate the other device for attack.
v	Browser extensions	They usually increase the productivity and sometimes enhance security as well.	As we know not all Browser extensions are safe and they can be used in any browser attack. So, usage of the browser extension should be avoided.
vi	Check the location of common Trojans	By detection of common trojans users can save themselves from identity theft.	Detection of trojan horse is very complex and it give false positive very frequently.
vii	Stay up to date on phishing techniques	Enables users to recognize fraudulent	It is completely user's wish and this is problematic.
viii	Use of encrypted DNS	It is very difficult to manipulate the DNS queries.	DNS represents a single point of failure.
ix	Use of HTTP/3	It may be more difficult for attackers to intercept and manipulate HTTP/3 traffic.	HTTP/3 is designed to operate over encrypted connections, primarily using Transport Layer Security (TLS). While this improves security, it can add cost and complexity, especially for sites that haven't adopted HTTPS.

6 | CLASSIFICATION OF BITM ATTACK PREVENTION METHODS

This section discusses various methods to detect the BITM attacks in detail.

6.1 | Unusual findings

BITM attacks are a sophisticated type of cyber assault that prey on browser flaws. Unusual findings in such attacks often reveal the assailant's capability to intercept and manipulate the communication between a user's browser and the intended server. By placing themselves in the way of the user and the website, these attackers are able to obtain sensitive data without authorization, including login passwords, private information, and financial information.³⁵

1. Various machine learning algorithms can be trained and used as a safety purpose for Internet user to monitor all his/her activities and predict the browsing habit for the user which will further helps to prevent the attack. Anomalies can be found using many methods like autoencoders, principal component analysis (PCA), and clustering.³⁶
2. Analysis of traffic patterns: By analyzing network traffic patterns, machine learning algorithms can spot unusual or unexpected traffic flows that might indicate a BITM attack. Models like Isolation Forests, One-Class SVMs, or LSTM networks can be used to do this.

6.2 | Certificate analysis for SSL/TLS

1. Verification of certificates: Machine learning models can be taught to identify the traits of legitimate SSL/TLS certificates. Any irregularities or inconsistencies in the properties of a certificate can cause an alert. Techniques for feature extraction and comparison can be used for this.²¹
2. Creating models to compute and store the fingerprints of trusted certificates is known as certificate fingerprinting. A certificate's fingerprint may reveal an attack if it changes unexpectedly.

6.3 | User behavior and authentication

6.3.1 | Keystroke dynamics

Create models to examine keystroke dynamics and typing patterns. A user who is restricted, may be revealed by slight variations from the set pattern. Machine learning models can be trained to recognize particular biometric patterns like mouse movements, touch gestures, or other behavioral indications for biometric authentication.

There are a lot of options available on the market for mobile device liveness detection and biometric and behavior-based authentication. Even with their extensive integration, they are frequently susceptible to presentation attacks, which include forging biometric data. Furthermore, the bulk of contemporary solutions are usually made to function in fixed usage contexts, including stationary postures, which has a detrimental effect on the user experience.^{37,38}

6.4 | Monitoring for data exfiltration

Train models to look for sensitive data leaking in the content of outgoing traffic. Techniques for natural language processing (NLP) can be used to spot patterns or terms that point to data exfiltration.

Organizations now view data security as a critical requirement due to the increasing risk of expensive data exfiltration incidents. Regretfully, insider threats—whether from people with genuine positions inside companies or from masked individuals who have gained insider credentials—have not been sufficiently addressed by attempts to safeguard the perimeters of corporate networks for example, through phishing and in our example, it is BITM attack.³⁹

6.5 | Security for browser extensions

Create machine learning models to track the behavior of browser extensions using extension behavior analysis. The model can issue a warning if an extension behaves maliciously or unexpectedly.

With the aim of filling gaps in ecosystem security assessment for browser extensions. Given the high level of privileges associated with extensions, it is beneficial for attackers to focus on weaker extensions, which opens the door to possible secret disclosure and unauthorized modification. By combining static and dynamic analysis, we can demonstrate how to identify extended insults and study their frequency in natural environments.⁴⁰ Whereas browser extensions offer profitable functionalities, clients and organizations must work out caution, select extensions from trustworthy sources, and execute security measures to ensure against potential security vulnerabilities and information breaches related with browser extensions.

6.6 | Analytics for user behavior

Machine learning-driven user profiling: By creating profiles of user activity, machine learning models can spot changes that can be signs of an ongoing MitM assault. The majority of worldwide web browsing activity is focused on popular websites, with entertainment being the most common online use case. Differences between desktop and mobile browsing habits are also highlighted.⁴¹

6.7 | Heuristics for traffic

Train models to spot network traffic patterns that point to MITM attacks using machine learning for heuristic analysis. Detecting abrupt and significant traffic redirection, for instance. With the aid of the Deep Inspector suite, which can detect malicious codes, DDoS attacks, SQL injection, Brute force, and other threats, the DLWSD method—which is based on the DNN deep learning network model will be able to detect any kind of network intrusion attack.⁴²

6.8 | Thorough package inspection

Machine learning-based DPI categorizes packets according to their content in order to identify malicious payloads or alterations. Packets can be obtained in a variety of methods for deep packet inspection. The most popular methods are to physically introduce a network tap, which copies the data stream and delivers it to an analyzer tool for inspection, and to use port mirroring, also commonly known as Span Port.^{43,44}

6.9 | Constant learning

Create machine learning models that can learn from new data continuously in order to adapt to evolving BITM attack techniques. Techniques like online education can be applied for this.

Keep in mind that the efficiency of these techniques depends on the Caliber and volume of the training data as well as the sophistication of the machine learning algorithms. Additionally, by integrating these methods with traditional security practices, a stronger resistance against BITM attacks is provided.⁴⁵

7 | USER AWARENESS TO PROTECT AGAINST BROWSER IN THE MIDDLE ATTACK

Users who undergo phishing awareness training are better equipped to defend themselves and their businesses against hackers, fraudsters, and other unscrupulous individuals aiming to steal and disrupt operations.²⁴ Your attitude and actions toward potential cyber-threats constitute the first line of defense for the internet. Phishing schemes conspire with victims to obtain login information for various private accounts, including email, workplace intranets, and more.^{37,46–52}

Even for vigilant users, recognizing a phishing attack can be challenging at times. Over time, these attacks become more sophisticated, and hackers learn to customize their cons, delivering highly convincing messages that can easily mislead individuals. Here are some security practices to follow:

Stay update: Always keep up to date with all the updates of the system and be aware about the cybersecurity news, trends, and potential threats. Follow the reputable sources such as security blogs and news outlets.

User training: Educate user about common cybersecurity risks including phishing attacks and all types of malware attacks. Conducting phishing simulation exercises is a proactive way to train users. These exercises simulate real-world phishing attacks to help users recognize phishing emails and respond appropriately. Providing workshops and training sessions involving hands-on activities and interactive elements can improve user engagement and understanding of phishing threats. Conduct ongoing awareness campaigns, including newsletters and posters and other visual aids can reinforce important cybersecurity messages and inform users about evolving threats. Using a variety of educational channels, such as online courses, webinars, and in-person training, ensures that diverse learning interests and needs are met.

Be aware when checking emails: Avoid clicking on suspicious links or downloading attachments from the unknown sources. Verify the sender's email address and always aware when providing personal information through emails.

Implement strong passwords/patterns: For every account user can use a different, complicated password. To save and manage user's credentials safely, think about using a password manager.

Regular Backups: Data backups should be performed on a regular basis. Important files should be securely stored. Internet Users can recover their data in the event of an attack without paying a ransom.

Avoid clicking on suspicious links: Please exercise caution when using links received through email, social media, or other channels. Hover your mouse over the link to see the destination before clicking.

Note any strange behavior: Be aware of sudden changes in browser behavior like weird pop-up windows, redirects, or warnings because BITM attack is a browser attack which is used to manipulate the content of the Web pages. For example: Sometimes we observe that when we open any website to download movies for free and the pop-ups on that website comes very frequently and if user click on these pop-ups, then user may be the victim of phishing attack and especially this attack will be known as BITM attack.

Never leave your Web browser open: Internet User should close their browser when they are done with their work because the BITM attack is contained in their web browser and by closing the browser it will interrupt the attack.

Install an antivirus: By installing an antivirus, we can detect BITM attack as these attacks also use trojans sometimes and configure user's antivirus to run at regular intervals.

Use of firewall: All major operating systems have built-in inbound firewalls, and all commercial routers on the market have built-in network address translation (NAT) firewalls. Make sure it is enabled.

Warning from the browser: If your browser warns you about the website you are trying to visit, you should pay attention and get the information you need elsewhere.

Never download pirated software use only genuine software: Internet users generally download pirated free products and they may sound tempting, but be aware that those who upload them are often trying to make money by compromising the system itself or selling your information to other web scammers. So, only buy genuine, reputable security software from trusted vendors.

Never give out personal information: As a general rule, never give out personal or financially sensitive information on the Internet. This rule dates back to the days of America Online, when early scams were so successful that users had to be constantly alerted. If in doubt, visit the company's main website, get their phone number, and give them a call. Most phishing emails redirect to pages that ask for personal or financial information. Internet users should avoid to send confidential information through links contained in e-mail. Do avoid to send emails containing confidential information to third parties. Get in the habit of checking website addresses. A secure website always starts with https.

By adopting these good security practices and staying informed about the latest threats, you can reduce the risk of falling victim to BITM attacks and other forms of cybercrime.

8 | LEGAL ACTIONS

8.1 | EU laws

Certainly, let's dig into the subtle elements of the important EU laws and orders concerning phishing assaults^{53–55}:

8.1.1 | Mandate on security of organize and data frameworks (NIS Order)

The NIS Order, formally known as Order (EU) 2016/1148, was received on July 6, 2016. It points to attain a tall common level of security of organize and data frameworks inside the EU and builds up particular prerequisites for administrators of fundamental administrations (OES) and advanced benefit suppliers (DSPs). Whereas not unequivocally focusing on phishing assaults, the order addresses the broader scope of cybersecurity dangers, which includes phishing. Key arrangements of the NIS Order incorporate:

Article 1:

Subject Matter and Scope:

This article diagrams the reason of the order, emphasizing the ought to upgrade cybersecurity flexibility and guarantee the working of the inner advertise.

Article 4:

Security Necessities for Administrators of Basic Administrations:

This segment imposes obligations on OES in basic segments, such as vitality, transport, keeping money, and health-care, to require suitable security measures and inform competent specialists of noteworthy occurrences, which seem incorporate phishing assaults influencing their frameworks.

Article 5:**Security Necessities for Advanced Benefit Suppliers:**

Essentially, this article commands DSPs, counting online marketplaces, look motors, and cloud computing administrations, to actualize security measures and report significant occurrences.

Article 14:**Participation:**

This arrangement emphasizes participation and data sharing among EU part states, empowering them to reply viably to cybersecurity occurrences, counting phishing assaults.

8.1.2 | Common information security control (GDPR)

The GDPR, Regulation (EU) 2016/679, could be a comprehensive information security and security direction embraced on April 27, 2016. Whereas its essential center is on protecting individuals' individual information, it in a roundabout way addresses phishing assaults by requiring organizations to actualize fitting security measures to protect individual information against unauthorized get to, counting phishing endeavors. Key arrangements of the GDPR important to phishing incorporate:

Article 32:**Security of Preparing:**

This article orders information controllers and processors to execute suitable specialized and organizational measures to guarantee a level of security suitable to the hazard, which incorporates assurance against phishing assaults.

Article 33:**Notice of an Individual Information Breach to the Supervisory Specialist:**

Organizations encountering an individual information breach, such as a phishing assault coming about in unauthorized get to individual information, must inform the important supervisory specialist without undue delay.

Article 34:**Communication of an Individual Information Breach to the Information Subject:**

In certain circumstances, organizations must too communicate individual information breaches to influenced individuals without undue delay, especially in case the breach is likely to result in a tall hazard to their rights and flexibilities.

8.1.3 | Order on assaults against data frameworks

The Order on Assaults Against Data Frameworks, Mandate 2013/40/EU, addresses cybercrimes, counting assaults against data frameworks, inside the EU. Whereas not particular to phishing assaults, it sets out rules concerning the definition of criminal offenses and punishments in this range. Key arrangements of this order incorporate:

Article 1:**Subject Matter and Scope:**

This article diagrams the reason of the order, which is to harmonize national laws with respect to the definition of criminal offenses and punishments related to assaults against data frameworks.

Article 3:**Illicit Get to:**

This segment characterizes the offense of illicit get to data frameworks and builds up punishments for culprits.

Article 4:

Illicit System Interference:

Additionally, this article characterizes the offense of illicit framework impedances, which incorporates activities pointed at disturbing the working of data frameworks, possibly encompassing certain forms of phishing assaults.

8.1.4 | National enactment

Whereas EU orders give a system for combating cybercrimes like phishing assaults, each EU part state may also have its possessed national enactment tending to such offenses. National laws must comply with EU mandates but may contain extra arrangements custom-made to the particular circumstances of each nation.

In rundown, whereas there is not a particular EU law exclusively committed to phishing assaults, a few mandates and controls address cybersecurity dangers broadly, which envelop phishing. These incorporate the NIS Order, GDPR, and the Order on Assaults Against Data Frameworks. Moreover, national enactment in each EU part state may moreover contribute to combating phishing assaults inside their particular purviews.

8.2 | IT law of India

In India, laws related to phishing assaults essentially drop beneath the ambit of the Data Innovation Act, 2000 (IT Act), and its consequent revisions. Here are a few key arrangements of the IT Act significant to phishing assaults.^{56–58}

1. Section 43: This section deals with unauthorized access to computer systems. Phishing attacks often involve unauthorized access to sensitive information or computer systems. Those found guilty under this section may face penalties.
2. Section 66: This section deals with computer-related offenses such as hacking. Phishing attacks involve fraudulent access to computer systems, which may be covered under this provision.
3. Section 66C: This section specifically addresses identity theft. Phishing often involves stealing personal or financial information to impersonate someone else, which may constitute identity theft under this provision.
4. Section 66D: This section covers cheating by personation by using computer resources. Phishing attacks often involve impersonating legitimate entities to deceive users, which may be punishable under this provision.
5. Section 72: This section deals with the breach of confidentiality and privacy. If personal or confidential information is obtained through phishing attacks and misused, it may be punishable under this provision.
6. Section 72A: This section deals with the disclosure of information in breach of lawful contract. If the phishing attack involves breaching confidentiality agreements or contracts, this provision may be applicable.
7. Section 85: This section specifies that provisions of the IT Act shall have effect notwithstanding anything inconsistent therewith contained in any other law for the time being in force. This means that the provisions of the IT Act will prevail in case of any inconsistency with other laws.

Apart from the IT Act, the Indian Penal Code (IPC) also contains provisions related to fraud, cheating, and impersonation, which may be applicable in cases of phishing attacks. Furthermore, the Reserve Bank of India (RBI) and the Securities and Exchange Board of India (SEBI) have issued guidelines and regulations to prevent phishing attacks in the banking and financial sectors.

The RBI has issued different circulars and rules pointed at improving cybersecurity and avoiding extortion, counting phishing assaults, within the keeping money segment. RBI's rules command banks and monetary teach to actualize vigorous security measures to ensure client data and anticipate unauthorized get to accounts. Banks are required to teach clients about security by keeping phishing awareness, counting mindfulness for phishing assaults and how to recognize and report them.

RBI has educating banks to actualize multi-factor confirmation for online exchanges to upgrade security and anticipate unauthorized get to. Banks are required to expeditiously report any episodes of phishing assaults or cybersecurity breaches to RBI and take fitting medicinal measures.

SEBI has issued rules and directions to guarantee the security and astuteness of the securities advertise and ensure financial specialists from false exercises, counting phishing assaults. SEBI controls require middle people such as stock-brokers, stores, and exchanging stages to execute vigorous cybersecurity measures to protect speculator data and avoid unauthorized access to attacker.

Mediators are ordered to conduct standard hazard evaluations and actualize satisfactory controls to moderate the chance of phishing assaults and other cyber dangers. SEBI requires mediators to teach speculators approximately secure speculation hones, counting mindfulness approximately phishing assaults and how to maintain a strategic distance from falling casualty to them. Mediators are required to expeditiously report any cybersecurity episodes, counting phishing assaults, to SEBI and take vital remedial activities.

It is essential to consult legal experts or practitioners for detailed and up-to-date information regarding laws and regulations related to phishing attacks in India.

9 | CONCLUSION AND FUTURE SCOPE

This paper has explored various facts of phishing through BITM and its utilization for phishing, along with its implications for data and system security. Additionally, it has delved into preventive techniques that can help avert or mitigate the damage caused by this type of attack. These safeguards encompass encryption, safeguarding data from unauthorized access; authentication, verifying the identity of users and devices; backup, ensuring data availability in case of loss or corruption; a firewall, blocking unwanted network traffic; antivirus, detecting and removing malicious software; and education, enhancing user and staff awareness and skills regarding phishing.

Moreover, the significance of user knowledge and vigilance in protecting personal and professional data against phishing is emphasized in this study. Users are often the primary target and source of phishing due to their susceptibility to persuasive emails or websites, or unwitting propagation of phishing links or documents. Consequently, users must be cognizant of common signs and risks of phishing and adopt good security practices such as verifying the sender's address, confirming the URL's domain, checking for spelling or grammar errors, refraining from clicking on suspicious links or attachments, and reporting phishing attempts.

Further future scope is to prepare a detection system which is capable of detecting BITM attack. Detection system should be detecting the attack as well as mitigate the attack so that the impact of the attack would be minimize. The browser fingerprint should be there in detection system which will monitor the browser for any malicious activity and able to detect it.

CONFLICT OF INTEREST STATEMENT

The authors declare no conflict of interest.

DATA AVAILABILITY STATEMENT

Data sharing is not applicable to this article as no new data were created or analyzed in this study.

ORCID

Ankit Kumar Jain  <https://orcid.org/0000-0002-9482-6991>

REFERENCES

1. Tzschoppe J, Löhr H. Browser-in-the-middle-evaluation of a modern approach to phishing. *Proceedings of the 16th European Workshop on System Security*; ACM; 2023:15-20.
2. Callegati F, Cerroni W, Ramilli M. Man-in-the-middle attack to the HTTPS protocol. *IEEE Secur Privacy*. 2009;7(1):78-81.
3. Tommasi F, Catalano C, Taurino I. Browser-in-the-middle (BitM) attack. *Int J Inf Secur*. 2022;21(2):179-189.
4. Bhushan B, Sahoo G, Rai AK. Man-in-the-middle attack in wireless and computer networking—a review. *2017 3rd International Conference on Advances in Computing, Communication & Automation (ICACCA)*. IEEE; 2017:1-6.
5. Phishing Report. Accessed September 17, 2023. <https://apwg.org/trendsreports/>
6. History of phishing. Accessed September 17, 2023. <https://cofense.com/knowledge-center/history-of-phishing/>
7. Information about CAPEC-701: Browser in the Middle (BITM). Accessed September 26, 2023. <https://capec.mitre.org/data/definitions/701.html>
8. Information about MITRE framework for enterprise. Accessed September 26, 2023. <https://attack.mitre.org/matrices/enterprise/>

9. Information about MITRE framework for mobile. Accessed September 26, 2023. <https://attack.mitre.org/matrices/mobile/>
10. Information about MITRE framework for ics. Accessed December 26, 2023. <https://attack.mitre.org/matrices/ics/>
11. Information about attack. Accessed March 28, 2023. <https://money.cnn.com/2017/05/03/technology/google-docs-phishing-attack/index.html>
12. Information about attack. Accessed March 28, 2023. <https://www.wired.com/story/google-docs-scams-threat-phishing/>
13. Information about attack. Accessed March 28, 2023. <https://www.cisa.gov/news-events/alerts/2017/05/04/google-docs-phishing-campaign>
14. Mallik A. Man-in-the-middle-attack: understanding in simple words. *Cyberspace*. 2019;2(2):109-134.
15. MITM definition and prevention. Accessed December 17, 2023. <https://www.itgovernance.eu/blog/en/how-to-defend-against-man-in-the-middle-attacks>
16. Rauti S, Leppänen V. Browser extension-based man-in-the-browser attacks against ajax applications with countermeasures. *Proceedings of the 13th International Conference on Computer Systems and Technologies*; ACM; 2012:251-258.
17. Utakrit N. Review of Browser Extensions, a Man-in-the-Browser Phishing Techniques Targeting Bank Customers. 2009.
18. Dougan T, Curran K. Man in the browser attacks. *Int J Ambient Comput Intell*. 2012;4(1):29-39.
19. Cain C. Analyzing Man-in-the-Browser (MITB) Attacks. 2014.
20. Wifi-Sniffer information. Accessed September 26, 2023. <https://www.solarwinds.com/network-performance-monitor/use-cases/wifi-packet-sniffer>
21. Brubaker C, Jana S, Ray B, Khurshid S, Shmatikov V. Using frankencerts for automated adversarial testing of certificate validation in SSL/TLS implementations. *2014 IEEE Symposium on Security and Privacy*. IEEE; 2014, May:114-129.
22. Ramachandran V, Nandi S. Detecting ARP spoofing: an active technique. *ICISS 2005 Information Systems Security: First International Conference*. Springer; 2005:239-250.
23. Security Used in Smart locks. Accessed September 26, 2023. <https://www.cnet.com/home/security/best-smart-locks/>
24. Benefits of multi-factor authentication. Accessed September 26, 2023. <https://www.loginradius.com/blog/identity/benefits-of-mfa/>
25. Zhang X et al. A study on the effectiveness of Trojan detection techniques using a red team blue team approach. *2013 IEEE 31st VLSI Test Symposium (VTS)*. IEEE; 2013.
26. Information on Trojan horses. Accessed September 26, 2023. <https://www.webroot.com/in/en/resources/tips-articles/what-is-trojan-virus>
27. Applebaum A et al. Intelligent, automated red team emulation. *Proceedings of the 32nd Annual Conference on Computer Security Applications*; ACM; 2016.
28. Ahmad A, Webb J, Desouza KC, Boorman J. Strategically-motivated advanced persistent threat: definition, process, tactics and a disinformation model of counterattack. *Comput Secur*. 2019;86:402-418.
29. Information about phishing attempts. Accessed September 26. <https://blog.checkpoint.com/2022/04/19/socialnetworks-most-likely-to-be-imitated-by-criminal-groups-with-linkedin-nowaccounting-for-half-of-all-phishing-attempts-worldwide/>
30. Information about vade secure phishers. Accessed September 26, 2023. <https://info.vadesecure.com/en/phishers-favorites-2021-year-in-review>
31. Information about CAPEC: Common attack pattern enumeration and classification. Accessed September 26, 2023. <http://capec.mitre.org>
32. Ellahi O, Umer M, Raza A, Rehman K. Analyzing 2FA phishing attacks and their prevention techniques. *2022 International Conference on Smart Information Systems and Technologies (SIST)*. IEEE; 2022:1-6.
33. Dhamija R, Tygar JD, Hearst M. Why phishing works. *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*; ACM; 2006:581-590.
34. Chiew KL, Yong KSC, Tan CL. A survey of phishing attacks: their types, vectors and technical approaches. *Expert Syst Appl*. 2018;106:1-20.
35. Bansal C, Bhargavan K, Delignat-Lavaud A, Maffei S. Discovering concrete attacks on website authorization by formal analysis. *J Comput Secur*. 2014;22(4):601-657.
36. Vijayalakshmi M, Mercy Shalinie S, Yang MH, Raja Meenakshi U. Web phishing detection techniques: a survey on the state-of-the-art, taxonomy and future directions. *IET Netw*. 2020;9(5):235-246.
37. Catalano C, Pagano A, Piccinno A, Stamerra A. Cartoons to Improve Cyber Security Education: Snow White in Browser in the Middle; 2023.
38. Progonov D, Cherniakova V, Kolesnichenko P, Oliynyk A. Behavior-based user authentication on mobile devices in various usage contexts. *EURASIP J Inf Secur*. 2022;2022(1):6.
39. Chung M-H, Yang Y, Wang L, et al. Implementing data exfiltration defense in situ: a survey of countermeasures and human involvement. *ACM Comput Surv*. 2023;55:1-37.
40. Eriksson B, Picazo-Sanchez P, Sabelfeld A. Hardening the security analysis of browser extensions. *Proceedings of the 37th ACM/SIGAPP Symposium on Applied Computing*; ACM; 2022.
41. Ruth K, Fass A, Azose J, et al. A world wide view of browsing the world wide web. *Proceedings of the 22nd ACM Internet Measurement Conference*; ACM; 2022.
42. Le HV, Du HP, Nguyen HN, et al. A proactive method of the webshell detection and prevention based on deep traffic analysis. *Int J Web Grid Services*. 2022;18(4):361-383.
43. Yin C, Wang H, Yin X, Sun R, Wang J. Improved deep packet inspection in data stream detection. *J Supercomput*. 2019;75:4295-4308.
44. Rajendran J, Jyothi V, Karri R. Blue team red team approach to hardware trust assessment. *2011 IEEE 29th International Conference on Computer Design (ICCD)*. IEEE; 2011.

45. Dixit P, Kohli R, Acevedo-Duque A, Gonzalez-Diaz RR, Jhaveri RH. Comparing and analyzing applications of intelligent techniques in cyberattack detection. *Security and Communication Networks*; hindawi; 2021:1-23.
46. Aljofey A, Jiang Q, Rasool A, et al. An effective detection approach for phishing websites using URL and HTML features. *Sci Rep*. 2022;12(1):8842.
47. Information about phishing URL detection. Accessed September 26, 2023. <https://towardsdatascience.com/phishing-domain-detection-with-ml-5be9c99293e5>
48. Information about information security. Accessed September 26, 2023. <https://www.techtarget.com/searchnetworking/definition/network-security>
49. Protection against phishing. Accessed September 26, 2023. <https://support.microsoft.com/en-us/windows/protect-yourself-from-phishing-0c7ea947-ba98-3bd9-7184-430e1f860a44>
50. Information about Social-phish. Accessed September 26, 2023. <https://www.geeksforgeeks.org/socialphish-phishing-tool-in-kali-linux/>
51. Information about phishing attack using Kali. Accessed September 26, 2023. <https://www.cybervie.com/blog/phishing-attack-using-kali-linux/>
52. Information about the phishing tools. Accessed January 16, 2024. <https://www.javatpoint.com/phishing-tools-for-kali-linux>
53. Information about EU Laws. Accessed March 18, 2023. https://home-affairs.ec.europa.eu/policies/internal-security/cybercrime_en
54. Information about EU Laws. Accessed March 21, 2023. <https://www.cybercrimelaw.net/EU.html>
55. Information about EU Laws. Accessed March 21, 2023. <https://www.itgovernance.co.uk/eu-cybersecurity-act>
56. Information about IT Law. Accessed March 22, 2023. <https://eprocure.gov.in/cppp/rulesandprocs>
57. Information about IT Law. Accessed March 22, 2023. <https://www.geeksforgeeks.org/cyber-laws-in-india/>
58. Information about IT Law. Accessed March 24, 2023. <https://www.meity.gov.in/content/cyber-laws>

How to cite this article: Jagannath RO, Jain AK. Browser-in-the-middle attacks: A comprehensive analysis and countermeasures. *Security and Privacy*. 2024;7(5):e410. doi: 10.1002/spy2.410